Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

Code | Issues | Pull requests 31 | Agents | Actions | Projects
Security and quality | Insights | Settings

Merge Status | Code

PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun) #81

Open abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

Conversation 9 | Commits 1 | Checks 1 | Files changed 1 +18

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant





abdulwaheed384 commented 4 hours ago — Owner

Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

Add PROM06 TC12 legitimate public HTTPS test ··· Unverified 9cee1fe

github-actions Bot commented 4 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 11 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 4 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 1

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_rule.tc12_public_https`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/tc12_https.tf`

github-actions Bot commented 4 hours ago

Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

Experiment condition: INDEPENDENT
Automated operational score: 50/100 — HIGH — DO_NOT_MERGE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 3 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · NSG rule permits unrestricted public inbound HTTPS to the entire subnet**
  - Category rationale: The Terraform code directly demonstrates that a priority-300 Allow rule for inbound TCP/443 from source '' *to destination* '' is added to the NSG that is associated with subnet-demo (azurerm_subnet_network_security_group_association.subnet in network.tf). Priority 300 is evaluated before the DenyAllInbound rule at priority 4096, so the rule is effective and opens public HTTPS ingress to all subnet resources. The file comment 'Research-only test fixture. Do not deploy.' directly contradicts inclusion in the deployable Terraform configuration; if applied, it constitutes an unscopable public exposure of all resources in the subnet.
  - Evidence: terraform/tc12_https.tf: resource azurerm_network_security_rule.tc12_public_https — priority = 300, direction = 'Inbound', access = 'Allow', protocol = 'Tcp', destination_port_range = '443', source_address_prefix = '', *destination_address_prefix =* '', network_security_group_name = azurerm_network_security_group.nsg.name. terraform/network.tf: azurerm_subnet_network_security_group_association.subnet associates the same NSG with subnet-demo. terraform/nsg.tf: DenyAllInbound is at priority 4096, evaluated after this rule.
  - Analysis: azurerm_network_security_rule.tc12_public_https sets source_address_prefix = '' *and destination_address_prefix =* '' with destination_port_range = '443', direction = 'Inbound', access = 'Allow', and priority = 300. Because the associated NSG (nsg-demo-ai) is bound to subnet-demo via azurerm_subnet_network_security_group_association.subnet, this rule permits any internet source to reach TCP/443 on any resource deployed into that subnet. Priority 300 is evaluated before the DenyAllInbound rule at priority 4096, making the rule immediately effective. The file header states 'Do not deploy', but no Terraform mechanism (e.g., count = 0, a feature flag, or workspace scoping) prevents the rule from being applied; it will be created on 'terraform apply'.
  - Impact: Any resource deployed into subnet-demo (10.0.1.0/24) is reachable on TCP/443 from any internet source while this rule is present. The intended deny-all inbound baseline is bypassed for HTTPS traffic. The 'Do not deploy' comment provides no technical guard against accidental application.
  - Recommendation: If this rule is genuinely a test fixture that must not be deployed, protect it with a Terraform conditional (e.g., count = var.enable_tc12 ? 1 : 0 defaulting to 0, or a separate test workspace). If public HTTPS is required for a specific resource, restrict destination_address_prefix to the explicit private IP of that resource rather than '*', and ensure the decision to expose the resource publicly is reviewed and approved before deployment.
- **MEDIUM · POLICY_OR_COMPLIANCE · SEC-001: Public exposure broader than documented justification**
  - Category rationale: Policy SEC-001 states no resource should be publicly exposed unless explicitly required and justified. The file comment documents the intent ('public HTTPS is required for the intended public web endpoint') but uses destination_address_prefix = '*', which exposes the entire subnet rather than a specific resource. The justification provided scopes to a single endpoint; the implemented rule scope is broader than that justification supports, making this a policy violation even accepting that some public HTTPS exposure is intended.
  - Evidence: terraform/tc12_https.tf: azurerm_network_security_rule.tc12_public_https — destination_address_prefix = '*'; description = 'TC12 test: public HTTPS is required for the intended public web endpoint.' Policy ai/policy.md SEC-001: 'No resource should be publicly exposed unless explicitly required and justified.'

Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

just the documented endpoint. The scope of exposure is not bounded to the justified resource.
  - Impact: Any future resource deployed into subnet-demo inherits public HTTPS exposure without an additional explicit justification or rule change, violating the principle that public exposure must be scoped to the justified resource.
  - Recommendation: Set destination_address_prefix to the specific private IP address of the intended public web endpoint resource. If no specific resource IP is known at rule-definition time, use an Application Security Group or document the scope gap and obtain explicit approval before merging.
- **LOW · POLICY_OR_COMPLIANCE · TAG-001: azurerm_network_security_rule.tc12_public_https missing mandatory tags**
  - Category rationale: TAG-001 requires all taggable Azure resources to include the mandatory tags (environment, owner, cost-center). The azurerm_network_security_rule resource type supports tags in the AzureRM provider v4 via a tags argument. The resource block in tc12_https.tf does not include a tags block. No other file supplies tags for this resource.
  - Evidence: terraform/tc12_https.tf: resource azurerm_network_security_rule.tc12_public_https — no tags argument present. terraform/nsg.tf: azurerm_network_security_group.nsg includes tags = local.common_tags. ai/policy.md TAG-001: 'All taggable Azure resources must include mandatory tags: environment, owner, cost-center.'
  - Analysis: The newly added azurerm_network_security_rule.tc12_public_https does not include a tags argument. Policy TAG-001 requires environment, owner, and cost-center tags on all taggable Azure resources. The AzureRM provider v4 azurerm_network_security_rule resource supports a tags block. The parent NSG (azurerm_network_security_group.nsg) carries local.common_tags, but tags are not inherited by the standalone rule resource.
  - Impact: The rule resource is untagged, violating TAG-001 and reducing cost attribution and ownership traceability for this test case.
  - Recommendation: Add tags = local.common_tags (or equivalent research tags) to the azurerm_network_security_rule.tc12_public_https resource block.

Policy mappings

- **SEC-001** — No Unjustified Public Exposure (finding F-001)
- **SEC-001** — No Unjustified Public Exposure (finding F-002)
- **TAG-001** — Mandatory Resource Tags (finding F-003)

Recommendation

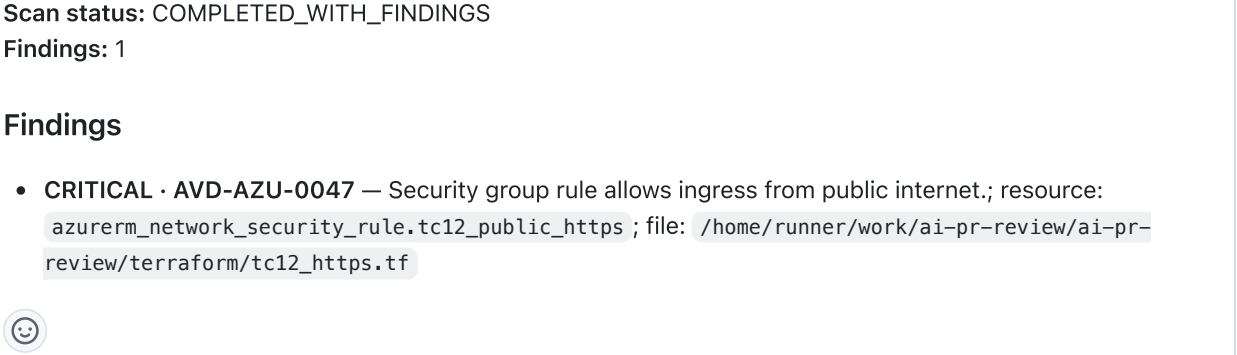
Review and remediate the confirmed findings above.

Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 11 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.



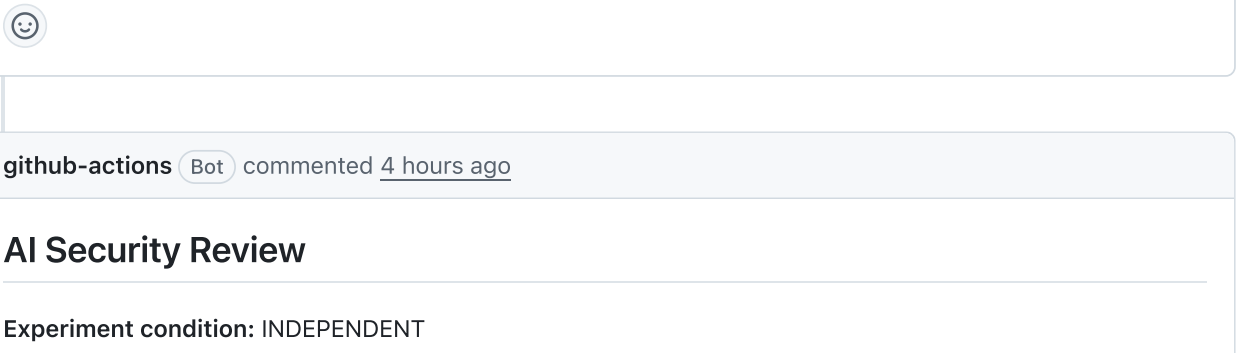
github-actions Bot commented 4 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 1

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_rule.tc12_public_https`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/tc12_https.tf`



github-actions Bot commented 4 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 95/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **LOW · POLICY_OR_COMPLIANCE · NSG security rule tc12_public_https is missing mandatory tags (TAG-001)**
  - Category rationale: TAG-001 requires all taggable Azure resources to include the mandatory tags: environment, owner, cost-center. The azurerm_network_security_rule resource supports tags and none are configured. This is a direct policy violation with clear Terraform evidence.
  - Evidence: resource "azurerm_network_security_rule" "tc12_public_https" in terraform/tc12_https.tf — no tags argument is present. local.common_tags is defined in terraform/main.tf and applied to all other taggable resources across network.tf and nsg.tf.

Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

(azurerm_network_security_group, azurerm_virtual_network, azurerm_resource_group, etc.) correctly reference local.common_tags. This resource is an outlier.

- Impact: The resource cannot be attributed to its cost-center or owner through standard Azure tag-based governance tooling, creating an accountability and cost-tracking gap consistent with the TAG-001 policy requirement.
- Recommendation: Add tags = local.common_tags (or a TC12-specific tags map that includes environment, owner, and cost-center) to the azurerm_network_security_rule.tc12_public_https resource block.

Policy mappings

- **TAG-001** — Mandatory resource tagging (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 11 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 1

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_rule.tc12_public_https`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/tc12_https.tf`



Open **PROM06 TC12 – Legitimate public HTTPS service (INDEPENDENT rerun)** #81

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc12`

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 100/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported no confirmed actionable findings.

Findings

No confirmed actionable findings reported by the AI reviewer.

Recommendation

No confirmed actionable findings require remediation.

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request

You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft